Document 14 — Incident Response and Key Event Reporting

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance and Information Security Officer
Version	0.1 — draft for licence application
Review	Annually; after every Severity 1 or 2 incident; after a test exercise
Relates to	LCCP 15.2.1 (reporting key events); LCCP 15.2.2 (other reportable events); RTS security requirements (ISO/IEC 27001:2022 5.24–5.28, 6.8); UK GDPR Articles 33–34; Proceeds of Crime Act 2002; Document 13

> Draft prepared from the platform as built on 30 September 2026. The key event list in §6 must be checked against the current LCCP before submission. `[BRACKETS]` must be completed.

1. Purpose

This procedure sets out how PlayStake spots, handles, records and reports incidents that threaten customer funds, customer data, game fairness or the availability of the service, and how we meet our duty to report key events to the Gambling Commission.

2. Reporting an incident

Anyone — staff, a referee, a supplier or a customer — who sees something that may be an incident reports it straight away to the Information Security Officer (ISO): [PHONE], [EMAIL], and in the operations channel. Customers report through support@playstake.org or the complaints form; support passes anything security-related to the ISO at once. Don't investigate alone, delete anything, or contact a suspected attacker.

Automatic triggers:

- ledger-audit worker failure (a balance or transaction that doesn't reconcile) — email alert to `EMAIL_ADMIN`;
- worker heartbeat missing (`/api/health` reports the worker down);
- error spikes in Sentry;
- anomaly, AML or player-risk alerts;
- supplier incident notices (Stripe, Railway, Resend, Kick, GAMSTOP).

3. Triage

The ISO decides severity within 1 hour of the report and records it in the incident register (§8).

Severity	Examples	Response
1 — Critical	Customer funds wrong or at risk; ledger doesn't reconcile; confirmed data breach; unauthorised admin access; a game deciding results wrongly; service unavailable to customers for more than 1 hour	Incident lead appointed at once; board informed within 4 hours; work continues until contained
2 — High	Suspected breach under investigation; fault affecting some customers' bets or limits; safer-gambling tool not working (limits, breaks, GAMSTOP check); supplier outage stopping deposits or withdrawals	Incident lead appointed same day; board informed within 24 hours
3 — Medium	Degraded performance; isolated bug with no money or data impact; blocked attack attempt	Handled in normal work; reviewed weekly
4 — Low	Near miss; policy breach without impact	Logged; reviewed monthly

A fault in a safer-gambling control is always at least Severity 2, and gambling for affected customers is stopped until it's fixed.

4. Response steps

1. **Contain.** Stop the harm first. Options, in order of preference:
   - suspend affected accounts (`/admin/users`);
   - turn off the affected feature or game (remove from `/play`, disable deposits by removing the payments flag);
   - stop the worker service if it is moving money wrongly;
   - put the web service into maintenance, or scale it to zero, in Railway;
   - rotate compromised secrets (Railway environment variables) and sign all users out (delete sessions).
2. **Preserve evidence.** Don't change or delete records. The ledger, game events and admin audit log are append-only. Export relevant application logs from Railway and Sentry before they age out; take a database snapshot; record every action taken, with times, in the incident record.
3. **Assess.** Which customers, how much money, what data, since when, and how. Use the ledger audit, game event log and admin audit log to establish the facts.
4. **Fix and recover.** Deploy the fix through CI (emergency change class, Document 11 §5). Restore from backup only if needed and only after preserving evidence. Correct any wrong payment with a new, reversing ledger transfer — never by editing records.
5. **Tell the people who need to know** (§5 and §6).
6. **Close and learn.** Within 10 working days of containment, a post-incident review records the cause, the impact, what worked, what didn't, and actions with owners. Policies, controls and tests are updated.

5. Notifying customers and others

Who	When	How
Affected customers	When their money, bets or data are affected. For a personal data breach likely to cause high risk, without undue delay (UK GDPR Art. 34).	Email and in-app message: what happened, what it means for them, what we've done, what they should do
Information Commissioner's Office	Personal data breach likely to risk people's rights and freedoms: **within 72 hours** of becoming aware (UK GDPR Art. 33)	ICO breach reporting service
Stripe	Suspected compromise of payment flows or Stripe credentials	Stripe support; rotate keys
National Crime Agency	Suspected money laundering or terrorist financing	Suspicious Activity Report by the MLRO (Policy 07)
Police / Action Fraud	Suspected crime, e.g. fraud or unauthorised access	Report online; record reference
Suppliers	Incident involving their service	Supplier's incident route
IBAS	Only as part of a customer's complaint	—

6. Key events: reporting to the Gambling Commission

LCCP 15.2.1 requires the Commission to be told of key events **as soon as reasonably practicable and in any event within five working days** of PlayStake becoming aware of them. Reports are made through the Commission's eServices portal by the Head of Compliance, who keeps a copy with the incident record.

Key events most relevant to PlayStake (check the full list in the current LCCP):

Key event	Example for PlayStake
A breach of information security that affects the confidentiality of customer data, or that stops customers accessing the gambling system for **more than 12 hours**	Leak of KYC documents; database exposed; outage over 12 hours
A fault in gambling software or systems that causes wrong payouts or losses to customers	Game deciding a wrong winner; settlement paying the wrong amount; limit not applied
Any change to where remote gambling equipment is located, or to the gambling software used	Moving Railway region or provider (Documents 08, 10)
Appointment or loss of key suppliers or significant changes to outsourcing	Change of payment provider or hosting
Criminal investigation or proceedings, or regulatory action elsewhere, involving PlayStake or its key people	—
Material financial events (e.g. insolvency, breach of banking covenants, significant loss)	—

Key event	Example for PlayStake
Changes to key people, ownership or control	Change of Head of Compliance / MLRO
Suspected cheating or match-fixing involving customers that has led to action	Collusion ring found and accounts closed

Other events under LCCP 15.2.2 (for example suspicion of offences, or information that may be relevant to the Commission) are reported as that condition requires.

What each report contains: what happened and when; when we became aware; customers, money and data affected; what we've done to contain and fix it; customer communications; further actions and dates; contact person.

7. Playbooks

Incident	First actions
Ledger audit fails	Stop the worker; identify the transaction(s); compare `balance` with the entry sum; no manual balance edits; correct with reversing transfers after sign-off; Severity 1
Game decides a wrong result	Remove the game from `/play`; list affected matches from `game_events`; void or correct with reversing transfers; tell affected customers; key event if payouts were wrong; test-house re-test before re-enabling
Leaked secret (API key, encryption key, database URL)	Rotate in Railway; redeploy; delete all sessions; review audit and access logs for use; for the KYC key, re-encrypt documents under a new key
Unauthorised admin access	Suspend the admin account; delete its sessions; review the admin audit log for every action; reverse unauthorised changes; reset 2FA
Outage	Check Railway status and `/api/health`; communicate on the site; if customers can't access the system for more than 12 hours, report as a key event
Safer-gambling tool failure	Stop gambling for affected customers (suspend or pause the feature); fix; review whether anyone gambled who shouldn't have and refund where appropriate
Supplier breach (e.g. Resend, Sentry)	Get facts from the supplier; assess what PlayStake data was involved; follow §5 and §6

8. Incident register

Every incident, including near misses, is recorded: reference, date and time reported, reporter, severity, description, customers/money/data affected, actions and times, notifications made (with references and times), root cause, lessons and actions, date closed. Kept for at least five years and reviewed at each quarterly compliance meeting.

9. Testing this procedure

A tabletop exercise is run at least annually (for example, a simulated KYC data leak and a simulated wrong-payout game fault), recorded, and used to update this document.

Version	Date	Change
0.1	30 September 2026	First draft